

CROSS-FRAMEWORK PRIVACY POLICY REWRITE

A Privacy Notice Design Deliverable

Comparative rewrite exercise: GDPR (EU) •
India's DPDP Act, 2023 • CCPA/CPRA •
OECD Privacy Guidelines • ISO/IEC 27701



Prepared by
Nikita Michael

CDPO Candidate Portfolio
Privacy Notice Design Project



July 2026



Educational Portfolio Disclaimer: This document is an original educational rewrite based on analysis of a publicly available privacy policy. It is prepared solely for learning and portfolio purposes and does not represent the official privacy notice of **Notion Labs, Inc.**

Contents

1. Executive Summary
2. Company Overview
3. Assessment of the Existing Privacy Policy
4. Design Principles
5. Layer 1 Privacy Notice
6. Layer 2 Detailed Privacy Policy
7. Cross-Jurisdiction Compliance Mapping
8. Readability Improvements
9. Key Takeaways

Scope note: This deliverable focuses on rewriting a public privacy notice to improve transparency and align it with the OECD Openness Principle, the GDPR, India's DPDP Act, and the CCPA/CPRA. It does not include broader privacy governance documentation.

1. Executive Summary

This deliverable rewrites the public privacy notice of a live, in-market SaaS product — Notion Labs, Inc., into a two-layer notice that reads clearly and holds up under three regimes at once: the GDPR, India’s Digital Personal Data Protection Act, 2023 (“DPDP Act”), and the CCPA/CPRA.

Most notices fail not because they omit information, but because the information is present and inaccessible. A notice that is legally complete but practically unreadable protects no one, and regulators are increasingly testing for comprehension, not just coverage.

The fix is architectural rather than cosmetic. A short Layer 1 summary gives any reader immediate orientation — what is collected, why, and how to act. A structured Layer 2 preserves the itemised detail that GDPR, the DPDP Act, and the CCPA each separately require. One design decision, applied consistently, satisfies three sets of obligations without three separate documents.

This report sets out the weaknesses in the existing notice, the design principles used to correct them, the rewritten notice in full, and a mapping of each section back to its governing legal requirement.

2. Company Overview

Company selected: Notion Labs, Inc. (“Notion”).

Source reviewed for identification purposes only, not reproduced: notion.com/trust/privacy-policy. Date accessed: 18 July 2026.

Selection rationale: Notion was selected because its publicly available privacy policy addresses consumer, enterprise, and AI-assisted processing in a single notice, making it well-suited for evaluating transparency obligations under the GDPR, India's DPDP Act, the CCPA/CPRA, and the OECD Openness Principle.

Notion is a workspace and productivity platform that combines notes, documents, wikis, project trackers, and AI-assisted features into a single product. Its users range from individuals managing personal notes to enterprises running internal knowledge bases and customer records through third-party integrations.

That range makes Notion a useful subject: the personal data flowing through it is unusually varied, account and profile data supplied directly by users; workspace content that may itself contain personal data about third parties, such as an enterprise customer's own customers or employees; technical and device data; billing data; and, where AI features are enabled, prompts and outputs shared with model providers. A single notice has to speak to a casual user and an enterprise controller at once — a fair test of whether a layered design works.

3. Assessment of the Existing Privacy Policy

The existing notice is not thin on coverage. It addresses the major categories of processing, third-party sharing, cross-border transfer, and jurisdiction-specific disclosure expected of a mature SaaS company, and it references recognised transfer-certification mechanisms without explaining what protection that certification actually gives a reader. That gap is the pattern running through the document: it was written to be legally defensible, not to be read. Information is present but not accessible, and legal precision has been prioritised over comprehension.

Each weakness below states why it matters, what it costs the reader, not just what is wrong, because that link is what justified every drafting choice in the rewrite.

Issue	Description	Why It Matters	Recommendation
Legalistic language	Formal, contract-style phrasing rather than everyday language.	Ordinary users skim past without absorbing what happens to their data.	Add a plain-language Layer 1 that precedes and mirrors the legal text.
Long, undivided paragraphs	Provisions run for many sentences, mixing several ideas per block.	Readers cannot scan for the one fact they need, so they disengage.	Cap paragraphs at three to four sentences; one idea each.
No plain-language summary	The notice opens straight into definitions, with no orientation section.	First-time readers get no quick answer to ‘what happens to my data’.	Add a Layer 1 summary answering the core questions in under 350 words.

Issue	Description	Why It Matters	Recommendation
Vague processing purposes	Purposes described broadly, e.g. ‘to operate and improve the Services’.	Individuals cannot judge proportionality or object to a specific use.	State each purpose separately, tied to a feature and legal basis.
Broad retention statements	Retention tied to business need rather than a defined period.	Individuals cannot judge how long data exists or when it is deleted.	Specify a retention period or deletion trigger per data category.
Thin explanation of rights	Rights listed by name only, without how to exercise them.	Users know rights exist in theory but not the steps to use them.	Pair every right with a channel and expected response time.
Weak layering and navigation	One continuous document, no contents list or jump links.	Finding one provision, e.g. transfer safeguards, means reading it all.	Add numbered headings and a short index to the detailed layer.
Consent/legal basis conflated	Consent, contract necessity, and legitimate interest not distinguished.	Legal basis governs what rights apply and how withdrawal works.	Separate the legal-basis section from consent mechanics.
Excessive cross-referencing	Obligations scattered across supplementary terms and help pages.	Readers must open several pages to reconstruct the full picture.	Summarise inline; link out only for exhaustive lists.

4. Design Principles

Every drafting choice traces back to one of five sources: the OECD Guidelines, GDPR, the DPDP Act, the CCPA/CPRA, or ISO/IEC 27701. Each is summarised here as a design instruction, not a legal citation — what it asks a notice to actually do.

OECD Openness Principle

Individuals should be able to establish that data is held about them, understand its main purposes, and identify who is responsible for it. That is the organising idea behind the rewrite: a short summary gives orientation, and a detailed second layer supplies the completeness a regulator would expect. Layering is openness put into practice.

GDPR Transparency (Articles 12–14)

GDPR requires information to be concise, transparent, and in plain language, and lists specific categories a controller must disclose at collection. Layer 1 satisfies the plain-language requirement; Layer 2 the itemised-disclosure requirement, together reflecting the layered-notice approach, Article 12 itself recognises as good practice.

DPDP Notice Requirements

The DPDP Act requires an itemised notice, in clear and plain language, describing the data collected and the purpose of each use, at or before collection. The consent section (Layer 2, S6.6) stands on its own as that itemised notice, and keeps affirmative consent clearly separate from other lawful bases.

CCPA/CPRA Disclosure

The CCPA/CPRA requires disclosure of categories of personal information collected, purposes, categories of third parties shared with, and rights to know, delete, correct, and opt out of sale or sharing. CCPA rights

are listed under their own heading, so a California resident can find their entitlements without reading GDPR-specific language first.

ISO/IEC 27701 Alignment

ISO/IEC 27701 extends a security management system into a Privacy Information Management System. Clause 7.2 (conditions for collection and processing) maps onto the Purposes and Legal Bases sections; clause 7.3 (obligations to PII principals) onto Individual Rights and Exercising Rights; and clause 7.4 (privacy by design) onto the decision to build a layered notice rather than one dense document. Treating the notice as the output of a managed system, not a one-off artefact, keeps it consistent with the organisation's wider controls.

Privacy by Design, applied

Privacy by Design is a working method here, not a heading. Data minimisation shows up in the push toward narrow, specific purposes rather than catch-alls. Proactive protection shows up in the default of no automated decision-making without human review. Visibility and transparency show up in the layered structure itself, built to be checked by a reader rather than trusted on faith.

5. Layer 1 Privacy Notice

Plain-language summary approximately 300 words. Written for a first-time reader with no legal background.

What information do we collect?

We collect the information you give us directly, your name, email address, and billing details, along with the content you choose to store in your workspace. We also automatically collect technical information, such as your device type, browser, and how you use our features. If you use AI-assisted features, we collect the prompts you enter and the responses generated.

Why do we collect it?

We collect this information to create and run your account, provide the features you use, keep the service secure, respond to support requests, and, where you have agreed, send you product updates.

How do we use it?

We use your information to operate the core product, personalise your workspace experience, detect and prevent misuse, process payments, and improve features based on aggregated usage patterns. We do not use the content of your workspace to train general-purpose AI models.

Who receives it?

We share information with service providers who help us run the platform, cloud hosting and payment processors, under contracts that limit their use of your data. If you invite collaborators into a workspace, they can see what you choose to share with them. We do not sell your personal information.

How long do we keep it?

We keep account information for as long as your account is active, and workspace content until you or your workspace administrator deletes it. After account closure, we retain limited data for a defined period to meet legal and security obligations, then delete or anonymise it.

Your privacy rights

Depending on where you live, you may have the right to access, correct, delete, or export your data; to object to or restrict certain processing; and to withdraw consent at any time. California residents have additional rights to know and to opt out of the sale or sharing of personal information, which we do not currently practise.

Contact us

You can exercise any of these rights, or ask us a question, by contacting our privacy team at the organisation's published privacy contact details (illustrative placeholder) or through the in-product help centre. Full details, including our complete policy, are set out in Layer 2 below.

6. Layer 2 Detailed Privacy Policy

Full rewritten notice, original language, organised for cross-framework compliance. Sections follow the natural lifecycle of data: collection, purpose, sharing, transfer, retention, security, and rights.

S6.1 Introduction · S6.2 Information We Collect · S6.3 Sources of Information · S6.4 Purposes of Processing · S6.5 Legal Bases (GDPR) · S6.6 Consent and Notice (DPDP) · S6.7 Sharing of Information · S6.8 International Data Transfers · S6.9 Cookies and Tracking · S6.10 AI-Assisted Features and Automated Decision-Making · S6.11 Data Retention · S6.12 Information Security · S6.13 Children's Privacy · S6.14 Individual Rights · S6.15 Exercising Rights · S6.16 Contact Details · S6.17 Updates to This Notice

6.1 Introduction

This notice explains how we collect, use, share, and protect personal data when you use our workspace platform, and describes the choices and rights available to you. It applies to website visitors, registered users, and individuals whose data our customers process through their workspaces. Where we process data on behalf of a customer who controls a workspace, that customer's own notice governs, and this document explains our role as their service provider.

Who is responsible for your data: [Company Name] is the controller for the data described in this notice, except where we act as a processor for a customer workspace. Our Data Protection Officer and EU representative can both be reached at the organisation's published Data Protection Officer contact details (illustrative placeholder), in line with GDPR Article 13(1)(a)–(b).

6.2 Information We Collect

- Account data: name, email address, password hash, and profile details provided at registration.
- Workspace content: pages, documents, databases, comments, and files created or uploaded by you or your collaborators.

- Usage and device data: browser type, IP address, operating system, pages viewed, and feature interactions.
- Billing data: payment method details processed through our payment provider, and billing history.
- AI interaction data: prompts submitted to, and outputs generated by, AI-assisted features, where enabled.
- Communications: messages sent to support, plus feedback and survey responses.

6.3 Sources of Information

Most information comes directly from you when you register, configure your workspace, or contact support. Some is generated automatically as you use the service. In enterprise deployments, information may also come from your organisation's administrator, for example, when inviting you to a workspace or configuring single sign-on.

6.4 Purposes of Processing

- To create, authenticate, and maintain your account.
- To provide, host, and synchronise workspace content across your devices.
- To process payments and manage subscriptions.
- To detect, investigate, and prevent fraud, abuse, and security incidents.
- To respond to support requests and communicate service updates.
- To generate aggregated, non-identifying analytics that inform product improvements.
- To operate AI-assisted features you choose to enable, subject to the safeguards in S6.10.

6.5 Legal Bases (GDPR)

Where the GDPR applies, we rely on: contract performance, to provide the core service; legitimate interests, to secure the platform and improve features, balanced against your rights; legal obligation, for tax and regulatory record-keeping; and consent, for optional communications and non-essential cookies. You may withdraw consent at any time without affecting prior processing.

6.6 Consent and Notice (DPDP)

Where the DPDP Act applies, we seek free, specific, informed, and unambiguous consent before processing data for purposes that require it, such as optional marketing. This notice is itemised at or before collection, describing the data collected and the purpose of each use, consistent with the Act's itemised-notice obligation. You may withdraw consent at any time through account settings; withdrawal is as easy as giving consent.

6.7 Sharing of Information

We share personal data only with: service providers processing data on our behalf under written contracts (hosting, payment, support vendors); your collaborators, to the extent you share workspace content with them; AI model providers, only when you use an AI-assisted feature and only to generate that response; advisers and regulators where required by law; and, in a merger or sale, a successor bound by an equivalent notice. We do not sell personal data or share it with third parties' own marketing.

6.8 International Data Transfers

Because our infrastructure and providers operate in multiple countries, data may be transferred outside your location. For transfers leaving the EEA or UK, we rely on recognised mechanisms such as standard contractual clauses or an adequacy decision. Where the DPDP Act restricts transfer to specific jurisdictions, we observe those restrictions.

6.9 Cookies and Tracking

We use strictly necessary cookies for core functions such as authentication, and, where you consent, analytics and preference cookies for aggregate usage. You can manage non-essential cookies at any time in the in-product settings, and your choice is honoured on every subsequent visit.

6.10 AI-Assisted Features and Automated Decision-Making

Where you use AI-assisted features, your prompts and outputs are processed by us and, where necessary to generate a response, by our AI model providers, under terms prohibiting those providers from training their own models on your content. These features assist you; they do not decide about you, we do not use them for decisions with legal or similarly significant effects without human involvement. If this changes for a feature, we will update this notice and provide the GDPR Article 22 safeguards, including a right to human review.

6.11 Data Retention

We keep personal data only for as long as necessary for the purpose it was collected, applying the following default periods.

Data Category	Retention Period	Trigger for Deletion
Account data	Duration of active account, plus 90 days	Account closure, then scheduled deletion
Workspace content	Until deleted by user or administrator	Manual deletion, subject to a 30-day backup cycle
Billing records	Up to 7 years	Expiry of applicable tax/accounting retention period
Support communications	Up to 2 years	Scheduled deletion after review window
AI interaction logs	Limited period, for safety monitoring only	Deleted or anonymised after the monitoring window

6.12 Information Security

We apply layered safeguards, including encryption in transit and at rest, role-based access controls, independent security testing, and continuous monitoring. We maintain an incident response process and notify affected customers and, where required, regulators, within the timeframes applicable law sets. We encourage strong, unique credentials and multi-factor authentication where available.

6.13 Children's Privacy

Our service is not directed at children under 16, and we do not knowingly collect personal data from children below the applicable age in their jurisdiction without verifiable parental or guardian consent where required. If we learn that a child's data was collected without necessary consent, we will delete it promptly.

6.14 Individual Rights

The rights available to you depend on where you live and which law applies to your data. We honour the following categories.

GDPR Rights

- Right of access to the personal data we hold about you.
- Right to rectification of inaccurate or incomplete data.
- Right to erasure, subject to legal retention obligations.
- Right to restrict or object to certain processing, including profiling for direct marketing.
- Right to data portability, in a structured, commonly used format.
- Right not to be subject to a solely automated decision with legal or similarly significant effect, and to request human review (Article 22).
- Right to lodge a complaint with your local supervisory authority.

DPDP Rights

- Right to a summary of personal data processed and the processing activities undertaken.
- Right to correction, completion, and updating of personal data.
- Right to erasure of data is no longer necessary for the stated purpose.
- Right to nominate another individual to exercise rights on your behalf on death or incapacity.
- Right to grievance redressal with us before escalating to the Data Protection Board, within the Act's prescribed timeline.

CCPA Rights

- Right to know categories and specific pieces of personal information collected, covering the preceding 12 months.
- Right to delete personal information, subject to statutory exceptions.
- Right to correct inaccurate personal information.
- Right to opt out of sale or sharing, including via a Global Privacy Control signal (we do not currently sell or share personal information as defined by the CCPA).
- Right to limit use of sensitive personal information.
- Right to non-discrimination for exercising these rights.

Where required for businesses of our size, we publish annual metrics on consumer rights requests in our transparency report.

6.15 Exercising Rights

You can exercise most rights directly from account settings, including access, correction, export, and deletion of your account data. For workspace content controlled by an organisation, we direct you to that organisation's administrator. For all other requests, contact our privacy team (S6.16). We verify identity before acting and respond within the timeframe required by law, generally 30 days.

6.16 Contact Details

Contact our privacy team at the organisation's published privacy contact details (illustrative placeholder) with questions or rights requests. Current contact details for our Data Protection Officer and EU representative are published on our trust centre and repeated in S6.1.

6.17 Updates to This Notice

We may update this notice as our services, obligations, or practices change. Where a change is material, we notify you by email or in-product notice before it takes effect, and prior versions remain available on request. Continued use after a material change acknowledges the update, without prejudice to any right to object under applicable law.

7. Cross-Jurisdiction Compliance Mapping

The table reads left to right: a section of the rewritten notice, then the requirement it satisfies under each framework. It is evidence, not decoration — proof that one piece of drafting does the work of four obligations at once, rather than four duplicated clauses.

Policy Section	GDPR	DPDP	CCPA	OECD Principle
S6.4 Purposes	Art. 13(1)(c) purposes/ basis	S4 itemised purpose notice	S1798.100 purposes disclosed	Purpose Specification
S6.5 Legal Bases (GDPR)	Art. 6 lawfulness	Primarily consent, S6.6; certain legitimate uses under S7 outside notice scope	No legal-basis concept	Accountability
S6.6 Consent (DPDP)	Art. 7 consent conditions	S5/6 free, informed consent	S1798.135 opt-out analogue	Individual Participation
S6.7 Sharing	Art. 13(1)(e) recipients	S8 disclosure to third parties	S1798.110 third-party categories	Use Limitation
S6.8 Intl Transfers	Arts. 44–49 transfer conditions	Central Govt transfer notification	No direct mandate; transparency duty	Openness

Policy Section	GDPR	DPDP	CCPA	OECD Principle
S6.10 AI & Automation	Art. 22 automated decisions	No direct equivalent yet	CPRA ADMT rules, phasing in through 2027	Individual Participation
S6.11 Retention	Art. 13(2)(a) retention period	S8(7) erasure once served	S1798.100(a)(3) retention disclosure	Data Quality
S6.12 Security	Art. 32 security of processing	S8(5) reasonable safeguards	S1798.150 reasonable security	Security Safeguards
S6.14 Rights	Arts. 15–22 data subject rights	S11–14 Data Principal rights	S1798.100 et seq. consumer rights	Individual Participation
S6.15 Exercising Rights	Art. 12(3) one-month response	S13 grievance timelines	S1798.130 verification timelines	Accountability

8. Readability Improvements

Readability is not a cosmetic layer added at the end; it is the mechanism through which the legal obligations actually reach the reader. Four effects are worth separating.

Accessibility

Numbered headings, short paragraphs, and bulleted lists support screen readers and make the notice easier to navigate on a phone. A reader looking for one fact, a retention period, or a contact address can find it without reading unrelated sections.

Plain language

Legal terms such as ‘data controller’ are introduced once, defined simply, and used consistently rather than swapped for synonyms. Sentences average under 20 words, and statements are phrased actively, ‘we collect’, ‘we share’, so it is always clear who is doing what.

Transparency

Retention periods, sharing recipients, and rights-response timelines are stated as concrete figures, not open-ended references to ‘as necessary’. Where a legal term is unavoidable, such as ‘legitimate interests’, it carries a one-line plain-language explanation immediately after it.

User trust

A notice that a person can finish reading builds more confidence than a technically complete one that goes unread. A casual user can stop after Layer 1; a procurement or legal reviewer continues into Layer 2 — each gets a complete answer at the depth they need.

Before and After — Illustrative Comparison

Element	Original Approach	Rewritten Approach
Purpose statement	“To operate and improve the Services.”	“To detect, investigate, and prevent fraud, abuse, and security incidents.”
Retention	“As long as reasonably necessary for business purposes.”	“Account data: active account plus 90 days.”

Element	Original Approach	Rewritten Approach
Rights	“You may have certain rights under applicable law.”	“Contact our privacy team; we verify identity and respond within 30 days.”
Structure	Single continuous document, no headings index.	Layer 1 summary plus a 17-section, numbered Layer 2.

9. Key Takeaways

Three findings from this engagement are worth carrying into future notice-drafting work.

1. The frameworks converge more than they conflict

GDPR’s demand for plain language, the DPDP Act’s itemised consent notice, and the CCPA’s categorical disclosures are not competing instructions; they are three routes to the same discipline: stating, in specific and checkable terms, what an organisation does with personal data. One well-structured architecture can satisfy all three without duplicated drafting.

2. Openness is a trust mechanism, not a checkbox

A notice a person can actually read and act on builds more confidence than a technically complete one that goes unread. Treating clarity as a compliance requirement, not a finishing touch, is the skill this project demonstrates.

3. Layering is the highest-leverage design decision

Nearly every weakness identified in S3, missing orientation, buried rights, and thin explanations, traces back to the absence of a layered structure. Introducing Layer 1 alongside a reorganised Layer 2 resolved most of them at once, which is why it belongs first in any similar engagement.

Recommended next step: pilot the Layer 1 summary with a small sample of real users before full rollout, and track whether ‘what happens to my data’ support queries decline, that is the real test of success.

REFERENCES

- Regulation (EU) 2016/679 (GDPR).
- Digital Personal Data Protection Act, 2023 (India).
- California Consumer Privacy Act (CCPA), as amended by CPRA.
- OECD Guidelines on the Protection of Privacy and Transborder Flows of Personal Data (2013).
- ISO/IEC 27701:2019.
- Notion Labs, Inc. Privacy Policy (publicly available), consulted for analysis and educational rewriting only.